

Stoquify PostgreSQL and Web Quality Review

PostgreSQL tenant controls, migrations, and EN/FR web quality

REVIEW REPORT

Prepared 2026-08-06

Evidence-led | read-only assessment | governance-first

Pinned sources. Explicit controls. Reproducible evidence.

Prepared: 2026-08-06 **Review mode:** Static, read-only source review **Skills applied:** supabase-postgres-best-practices, web-quality-audit

No SQL was executed and no application, schema, migration, or configuration files were changed during the review.

Scope limitation

The worktree contained no proposed Prisma schema or migration diff. The database assessment therefore used the current [prisma/schema.prisma](../prisma/schema.prisma) and the newest migration, [20260801153000_certified_fiscal_evidence_immutability/migration.sql](../prisma/migrations/20260801153000_certified_fiscal_evidence_immutability/migration.sql), as the available review scope. Any proposal maintained outside the worktree remains unassessed.

Database findings

High priority

DB-H1. Tenant isolation is not enforced at the database boundary

Fiscal child records have separate `organizationId` and parent foreign keys, but no composite constraint ensures that both belong to the same tenant. `FiscalDocumentLine`, `ComplianceSubmission`, and `ComplianceEvidence` can technically reference another organization's fiscal document.

Evidence:

- 1 [prisma/schema.prisma:6331](../prisma/schema.prisma#L6331)
- 1 [prisma/schema.prisma:6397](../prisma/schema.prisma#L6397)
- 1 [prisma/schema.prisma:6505](../prisma/schema.prisma#L6505)
- 1 [20260727143000_country_adapter_pilot_foundation/migration.sql:345](../prisma/migrations/20260727143000_country_adapter_pilot_foundation/migration.sql#L345)
- 1 The runtime exposes an unscoped `PrismaClient`: [prisma/db.ts:8](../prisma/db.ts#L8)

No row-level-security policy DDL was found in the migration history. Application query filters reduce risk, but they are not a database-enforced tenant guarantee.

DB-H2. Outbox leases can be claimed by multiple workers

Leasing selects eligible rows and then updates each row by `id` only. There is no row lock or conditional status/lease predicate during the update. Concurrent workers can select the same submissions, overwrite leases, and increment attempts twice.

Evidence:

- 1 Selection: [services/compliance/certification-outbox.service.ts:234](../services/compliance/certification-outbox.service.ts#L234)
- 1 Subsequent updates: [services/compliance/certification-outbox.service.ts:249](../services/compliance/certification-outbox.service.ts#L249)

DB-H3. An external adapter call occurs inside a database transaction

Processing is wrapped in `$transaction`, changes the submission to `SUBMITTED`, and then awaits `adapter.submit` while the transaction remains open. This holds a pooled connection across network latency and can leave an accepted external submission without committed local evidence if the database transaction later fails or times out.

Evidence:

- 1 Transaction wrapper: [services/compliance/certification-outbox.service.ts:898](../services/compliance/certification-outbox.service.ts#L898)

- 1 Pre-call database update: [services/compliance/certification-outbox.service.ts:713](../../services/compliance/certification-outbox.service.ts#L713)
- 1 External call inside the transaction: [services/compliance/certification-outbox.service.ts:730](../../services/compliance/certification-outbox.service.ts#L730)
- 1 Fifteen-second transaction timeout: [prisma/db.ts:10](../../prisma/db.ts#L10)

DB-H4. The immutability trigger can be bypassed during certification

Protection is based on the row's `OLD.status`. A non-certified document can therefore have protected fields changed in the same statement that transitions it to `CERTIFIED`. The trigger does not validate the protected-field integrity of that transition.

Evidence:

- 1 [20260801153000_certified_fiscal_evidence_immutability/migration.sql:32](../../prisma/migrations/20260801153000_certified_fiscal_evidence_immutability/migration.sql#L32)
- 1 [20260801153000_certified_fiscal_evidence_immutability/migration.sql:40](../../prisma/migrations/20260801153000_certified_fiscal_evidence_immutability/migration.sql#L40)

DB-H5. Parent certification and child writes have an unprotected concurrency window

Child triggers read the parent status with a plain `SELECT` and do not lock the parent. A child mutation can observe a pre-certification status concurrently with certification.

Evidence:

- 1 Fiscal document lines: [migration.sql:85](../../prisma/migrations/20260801153000_certified_fiscal_evidence_immutability/migration.sql#L85)
- 1 Compliance submissions: [migration.sql:127](../../prisma/migrations/20260801153000_certified_fiscal_evidence_immutability/migration.sql#L127)
- 1 Compliance evidence: [migration.sql:198](../../prisma/migrations/20260801153000_certified_fiscal_evidence_immutability/migration.sql#L198)

Medium priority

DB-M1. Some foreign-key indexes have the wrong leading column

`ComplianceEvidence` only has organization-leading composite indexes for `fiscalDocumentId` and `submissionId`. PostgreSQL cannot efficiently use the second column alone for parent referential-action checks or queries filtered only by that foreign key.

Evidence: [prisma/schema.prisma:6533](../../prisma/schema.prisma#L6533)

DB-M2. The lease query index does not fully match its ordering

The lease query filters by organization, status, and `nextAttemptAt`, but orders by `createdAt`. The current index ends at `nextAttemptAt`, leaving ordering or part of the filtering to additional work.

Evidence:

- 1 Query: [certification-outbox.service.ts:234](../../services/compliance/certification-outbox.service.ts#L234)
- 1 Index: [prisma/schema.prisma:6445](../../prisma/schema.prisma#L6445)

DB-M3. Rollback safety is undocumented and untested

The migration installs custom functions and triggers but has no inverse migration or tested removal procedure. The SQL file itself contains no explicit transaction boundary. Custom trigger removal and restoration behavior therefore remains operationally unproven.

Evidence: [migration.sql:236](../prisma/migrations/20260801153000_certified_fiscal_evidence_immutability/migration.sql#L236)

Prisma guidance confirms that database features such as triggers require custom migration SQL and that rollback procedures must be designed explicitly:

1 [Prisma: Generating down migrations](#)

1 [Prisma: Unsupported database features](#)

DB-M4. Migration tests validate text rather than PostgreSQL behavior

The tests assert that SQL fragments exist. They do not execute the migration or test concurrent writes, cross-tenant references, direct certification transitions, failed deployment, or rollback.

Evidence: [scripts/__tests__/compliance-fiscal-evidence-immutability-migration.test.js:1](../scripts/__tests__/compliance-fiscal-evidence-immutability-migration.test.js#L1)

DB-M5. Pooling compatibility is not established

The Prisma datasource exposes only DATABASE_URL. No separate direct migration connection, pool mode, prepared-statement compatibility, or connection-budget contract is visible. The long external-call transaction makes this omission more consequential.

Evidence: [prisma/schema.prisma:34](../prisma/schema.prisma#L34)

Web quality findings

No critical web-quality issue was established by the static review.

High priority

WEB-H1. Registration labels and errors are not programmatically associated with fields

FieldShell renders a visible Label without htmlFor, while its inputs have no corresponding IDs. Error text has no ID, role="alert", or aria-describedby relationship. Select controls have the same label-association problem. This affects both /en/register and /fr/register.

Evidence:

- 1 Field usage: [components/auth/BeautifulRegisterForm.tsx:266](../components/auth/BeautifulRegisterForm.tsx#L266)
- 1 Unassociated label: [components/auth/BeautifulRegisterForm.tsx:621](../components/auth/BeautifulRegisterForm.tsx#L621)
- 1 Unassociated error: [components/auth/BeautifulRegisterForm.tsx:628](../components/auth/BeautifulRegisterForm.tsx#L628)
- 1 Select label: [components/auth/BeautifulRegisterForm.tsx:334](../components/auth/BeautifulRegisterForm.tsx#L334)

WEB-H2. The login "remember me" control does not control session persistence

Authentication always sends rememberMe: true, while the visible checkbox is not bound to form state. The interface gives users a misleading security and privacy choice.

Evidence:

- 1 Authentication value: [components/auth/EnhancedLoginForm.tsx:91](../components/auth/EnhancedLoginForm.tsx#L91)
- 1 Unbound checkbox: [components/auth/EnhancedLoginForm.tsx:232](../components/auth/EnhancedLoginForm.tsx#L232)

Medium priority

WEB-M1. The registration wizard lacks accessible step and focus management

Its visual progress bar has no progress semantics. Future-step buttons remain focusable but silently do nothing, and step transitions do not move focus or announce the newly displayed step.

Evidence:

- 1 Progress display: [BeautifulRegisterForm.tsx:224](../../components/auth/BeautifulRegisterForm.tsx#L224)
- 1 Step buttons: [BeautifulRegisterForm.tsx:241](../../components/auth/BeautifulRegisterForm.tsx#L241)
- 1 Step transition: [BeautifulRegisterForm.tsx:124](../../components/auth/BeautifulRegisterForm.tsx#L124)

WEB-M2. Login validation messages are not associated with inputs

Login labels are correctly connected, but validation errors lack `aria-invalid`, IDs, live-region semantics, and `aria-describedby` references. Login and registration inputs also omit browser autocomplete purposes.

Evidence:

- 1 Associated label:
[components/auth/EnhancedLoginForm.tsx:164](../../components/auth/EnhancedLoginForm.tsx#L164)
- 1 Unassociated error:
[components/auth/EnhancedLoginForm.tsx:188](../../components/auth/EnhancedLoginForm.tsx#L188)

WEB-M3. Public routes give up static delivery and carry broad client overhead

The locale layout forces dynamic rendering and passes the complete locale message catalog into a client provider. The raw locale catalogs are approximately 150–159 KB each. Landing rendering also waits for a session lookup, while every public route receives query, authentication, notification, upload, and theme providers.

Evidence:

- 1 Forced dynamic rendering: [app/[locale]/layout.tsx:10](../../app/%5Blocale%5D/layout.tsx#L10)
- 1 Complete messages passed to the client provider:
[app/[locale]/layout.tsx:25](../../app/%5Blocale%5D/layout.tsx#L25)
- 1 Landing session lookup:
[app/[locale]/(home)/layout.tsx:27](../../app/%5Blocale%5D/%28home%29/layout.tsx#L27)
- 1 Global providers: [components/Providers.tsx:22](../../components/Providers.tsx#L22)

This is a credible TTFB and JavaScript-payload risk. No Core Web Vitals failure is claimed without runtime measurement.

WEB-M4. EN and FR routes lack localized SEO metadata

Both languages inherit one English title and description. No route-specific canonical, alternate-language metadata, social metadata, or authentication `noindex` declarations are defined in the landing, login, or registration route files. No application `robots.txt` or sitemap was found. `metadataBase` also falls back to localhost when deployment variables are absent.

Evidence:

- 1 Root metadata: [app/layout.tsx:11](../../app/layout.tsx#L11)
- 1 Localhost fallback: [app/layout.tsx:12](../../app/layout.tsx#L12)
- 1 Login route:
[app/[locale]/(auth)/login/page.tsx:1](../../app/%5Blocale%5D/%28auth%29/login/page.tsx#L1)
- 1 Registration route:
[app/[locale]/(auth)/register/page.tsx:1](../../app/%5Blocale%5D/%28auth%29/register/page.tsx#L1)

WEB-M5. Browser security policy is permissive and duplicated

Production CSP still permits inline scripts and styles, while `connect-src` permits every HTTPS and WSS origin. Security headers are separately defined in middleware and `next.config.mjs`, including different HSTS durations.

Evidence:

- 1 Script policy: `[middleware.ts:12](../../middleware.ts#L12)`
- 1 CSP: `[middleware.ts:25](../../middleware.ts#L25)`
- 1 Middleware HSTS: `[middleware.ts:21](../../middleware.ts#L21)`
- 1 Next configuration HSTS: `[next.config.mjs:139](../../next.config.mjs#L139)`

WEB-M6. No keyboard skip link was found

Landing and authentication shells contain main-content landmarks, but no skip-to-main control precedes repeated navigation.

Evidence:

- 1 Authentication main landmark:
`[components/auth/AuthLayout.tsx:184](../../components/auth/AuthLayout.tsx#L184)`
- 1 Landing main landmark:
`[app/[locale]/(home)/page.tsx:16](../../app/%5Blocale%5D/%28home%29/page.tsx#L16)`

Controls observed

- 1 Correct locale-specific `<html lang>` output: `[app/layout.tsx:31](../../app/layout.tsx#L31)`
- 1 Explicit EN and FR authentication copy:
`[components/auth/auth-copy.ts:3](../../components/auth/auth-copy.ts#L3)` and
`[auth-copy.ts:295](../../components/auth/auth-copy.ts#L295)`
- 1 Authentication pages have one shell-level H1 with form-level H2 headings:
`[components/auth/AuthLayout.tsx:233](../../components/auth/AuthLayout.tsx#L233)`
- 1 Landing images use `next/image`, explicit dimensions, translated alternative text, and responsive sizes:
`[components/landing/product-gallery.tsx:33](../../components/landing/product-gallery.tsx#L33)`
- 1 Landing motion has a reduced-motion override:
`[app/[locale]/(home)/landing.css:314](../../app/%5Blocale%5D/%28home%29/landing.css#L314)`
- 1 Several landing tabs and carousels have useful ARIA semantics and controls:
`[module-deep-dives.tsx:88](../../components/landing/module-deep-dives.tsx#L88)` and
`[connected-workflow.tsx:165](../../components/landing/connected-workflow.tsx#L165)`

Assessment boundary

This was a static source review only. It does not constitute accessibility certification and did not measure Lighthouse scores, Core Web Vitals, browser console behavior, color contrast, screen-reader behavior, or production response headers.